

Pass-the-Ticket, ACL y trusts en Active Directory

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

Pass-the-Ticket reutiliza un TGT o TGS válido sin conocer la password. Las ACL conceden acciones sobre objetos del dominio y los trusts conectan límites de autenticación entre dominios o bosques.

AD decide acceso por identidades, tickets y permisos encadenados. Un ticket robado o una ACL como GenericAll, WriteDACL o ForceChangePassword puede abrir una ruta que no aparece al mirar solo grupos directos.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando obtienes un ccache/kirbi, BloodHound muestra una arista abusada o el dominio mantiene trusts con otros dominios.

Cómo identificarla

- ccache
- kirbi
- KRB5CCNAME
- GenericAll
- WriteDACL
- ForceChangePassword
- TrustedDomain

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Comprueba identidad, realm, validez temporal y servicio accesible con Kerberos; valida cada ACL o trust antes de ejecutar cambios.

Evidencia esperada: Una ruta de identidad a recurso o privilegio con precondiciones, limite de alcance e impacto demostrable.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
impacket-getTGT $DOMAIN/$USER:$PASS -dc-ip $IP
```

Objetivo y contexto: Obtiene un TGT de laboratorio y crea el ccache que usaras para validar autenticacion por ticket.

Resultado esperado: Fichero ccache y periodo de validez del ticket.

Capa 2: prueba documentada

```
export KRB5CCNAME=$USER.ccache; impacket-psexec -k -no-pass $DOMAIN/$USER@$DC_FQDN
```

Objetivo y contexto: Demuestra autenticacion Kerberos con ticket sin volver a enviar la password.

Resultado esperado: Acceso autorizado o error de realm, DNS, hora o permisos que debes interpretar.

Anatomía de los payloads

La primera prueba es `impacket-getTGT $DOMAIN/$USER:$PASS -dc-ip $IP`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Una ruta de identidad a recurso o privilegio con precondiciones, limite de alcance e impacto demostrable.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Confirma realm, DNS y hora.
- Inspecciona tickets y permisos.
- Selecciona una accion minima.
- Valida acceso Kerberos sin password.
- Documenta la cadena completa.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- El ticket esta expirado, pertenece a otro realm o el reloj no esta sincronizado.
- La arista de BloodHound no concede una accion util sobre el objetivo.
- El dominio confiado queda fuera de alcance.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

Transformar tickets, permisos de objetos y relaciones de confianza en rutas de movimiento lateral explicables. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y precondiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (ad-tickets-trusts)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.